# Combined US Operations of Banco Santander, S.A.

## Technology




# Linux Servers Red Hat

# Hardening Guide

## DOCUMENT HISTORY AND VERSION CONTROL

### Ownership and Authorship

| Version | Date | Author | Owner | Change |
|---|---|---|---|---|
| 1.0 | 8/9/2022 | Victor Fallas | Scott Cain | Initial Version |
| 1.1 | 1/12/2023 | Victor Fallas | Scott Cain | Update effective date from December 31st, 2022 to June 30th 2023 in section 2.2 due to outages with SCUSA and year end freeze impacting original dates. |
| 1.2 | 6/20/2023 | Victor Fallas | Scott Cain | Aligned with lates CIS benchmark. CIS Red Hat Enterprise Linux 7 v3.1.1 No rule changes |
| 2.0 | 10/16/2024 | Santander US Infrastructure Operations | Santander US Head of Infrastructure Operations | Aligned with latest CIS benchmark. CIS Red Hat Enterprise Linux 7 v4.0.0/ CIS benchmark. CIS Red Hat Enterprise Linux 8 v3.0.0/ CIS benchmark. CIS Red Hat Enterprise Linux 9 v2.0.0/<br>2 Rules (1.1.2.1.4 & 1.1.2.3.1) for RHEL 7&8 moved to Out of Scope. RHEL 9 remains in Scope. |
| 3.0 | 1/5/2026 | Santander US Infrastructure Operations | Santander US Sr. Director, Infrastructure Operations | Updated to align with latest CIS and Global guide. Moved several rules from In Scope to Out of Scope. Comliance configuration date updated. Added note that applicable for RHEL 9 as well to inscope section |

### Sign Off

| Role / Function | Action | Date |
|---|---|---|
| Technology and Operations (“T&O”) Policy Administration Team | Review | 1/5/2026 |
| Santander US Chief Information Security Officer (“CISO”) | Approve | 1/5/2026 |
| Santander US Head of Infrastructure and Operation | Approve | 1/5/2026 |

# Table of Contents

DOCUMENT HISTORY AND VERSION CONTROL ..... 2
OWNERSHIP AND AUTHORSHIP ..... 2
SIGN OFF ..... 2
1 INTRODUCTION ..... 4
1.1 PURPOSE OF THIS DOCUMENT ..... 4
1.2 SCOPE ..... 4
1.3 OUT OF SCOPE ..... 4
2 CONTROLS AND MONITORING ..... 5
2.1 CONTROLS ..... 5
2.2 MONITORING ..... 5
3 GOVERNANCE / OVERSIGHT ..... 5
4 RED HAT CONFIGURATION ..... 6
4.1 ANTI-VIRUS CROWDSTRIKE - INSTALLED ..... 6
4.2 IN SCOPE MEASURABLE ..... 6
4.3 OUT OF SCOPE ..... 21
5 RELATED DOCUMENTS ..... 43
6 SOURCE DOCUMENTS ..... 43
7 SUBSIDIARY ENDORSEMENT ..... 44

# 1 INTRODUCTION

## 1.1 Purpose of this Document

The Linux Red Hat Servers Hardening Guide (this “Hardening Guide”) provides an overview of the mandatory security configuration for the Linux Red Hat Servers residing physically in Combined US Operations of Banco Santander, S.A. (“CUSO”), including the business units operating through Santander Holdings USA, Inc. (“SHUSA”) and its subsidiaries (individually, “Subsidiary,” collectively, “Subsidiaries,” and together with SHUSA, “Santander US”) and the Banco Santander, S.A. New York Branch (“BSNY”) data centers, that are managed by Infrastructure Operations within Technology.

## 1.2 Scope

This Hardening Guide applies to all subsidiaries that have Linux Red Hat Servers and all supported Red Hat servers located in the US and Mexico. Subsidiaries are not required to separately approve this Hardening Guide as this subject matter is managed centrally by the CUSO Technology function.

In scope are those servers with the status of “Deployed and being Assembled”. In Scope incudes both “Measurable” and “Non-Measurable” items. All rules listed as “In Scope” must be enforced as part of remediation. However, compliance reporting is required only for “Measurable” rules. In Scope rules may be “Unmeasurable” if automating compliance reporting is not possible or impractical.

## 1.3 Out of Scope

The Center for Internet Security (“CIS”) rules that are considered “out of scope” are the rules not applicable to the Technology infrastructure environment due to:

- Conflicts with other technical standards
- Application functionalities
- Technical designs
- Overlaps with other hardening rules covered by other guides (e.g. OS Hardening)
- Operational impact

The Red Hat Administrator should review the Out of Scope section carefully before deploying new databases. From the Out of Scope rules, only rules that do not apply to new servers should be considered when deploying new Red Hat Servers.

# 2 CONTROLS AND MONITORING

## 2.1 Controls

All employees responsible for installing and deploying the Red Hat servers are required, by their supervisors, to first learn the rules within this document and then to use this document and the other corresponding Red Hat documents to maintain the controls that are described in the documents. The Infrastructure managers are responsible for ensuring this Hardening Guide is followed.

## 2.2 Monitoring

Technology Infrastructure will compile and maintain the reporting metrics summarizing the hardening of all the Red Hat Servers in the Key Performance Indicator ("KPI") report. The KPI report is used to evaluate current hardening levels of all systems. These KPIs are presented in the monthly Technology Infrastructure Monthly Operating Review ("MOR") meeting. The report is accessible to all Bank Business Lines for review every month.

Note: The effective date for providing compliance evidence related to this Hardening Guide for all subsidiaries that this Hardening Guide applies to is May 30th 2026.

# 3 GOVERNANCE / OVERSIGHT

This Hardening Guide is reviewed and approved by the Santander US CISO and owned and approved by the Santander US Head of Infrastructure and Operations. Santander US Technology Infrastructure will communicate this document with Santander US stakeholders upon approval.

This Hardening Guide is reviewed annually or when a material change to the operating environment, potential changes to regulations and contractual requirements, potential findings, or requested policies exceptions necessitate an out of cycle review, following the Santander US Process and Administrative Document Approval Procedure.

# 4 RED HAT CONFIGURATION

## 4.1 Anti-Virus CrowdStrike - Installed

Crowdstrike Antivirus software works to block viruses from entering your computer system and kill or quarantine viruses that have some broken through the firewall.

## 4.2 In Scope Measurable

*(Applicable for RHEL 7, 8 & 9)*

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Expected Value |
|---|---|---|---|---|
| | **1.1.1** | **Configure Filesystem Kernel Modules** | | |
| 1 | 1.1.1.1 | Ensure cramfs kernel module is not available | The cramfs filesystem type is a compressed read-only Linux filesystem embedded in small footprint systems. A cramfs image can be used without having to first decompress the image. | /etc/modprobe.d/*.conf<br>install cramfs /bin/false or install cramfs /bin/true<br>blacklist cramfs |
| 2 | 1.1.1.2 | Ensure freevxfs kernel module is not available | The freevxfs filesystem type is a free version of the Veritas type filesystem. This is the primary filesystem type for HP-UX operating systems. | /etc/modprobe.d/*.conf<br>install freevxfs /bin/false or install freevxfs /bin/true<br>blacklist freevxfs |
| 3 | 1.1.1.3 | Ensure hfs kernel module is not available | The hfs filesystem type is a hierarchical filesystem that allows you to mount Mac OS filesystems. | /etc/modprobe.d/*.conf<br>install hfs /bin/false or install hfs /bin/true<br>blacklist hfs |
| 4 | 1.1.1.4 | Ensure hfsplus kernel module is not available | The hfsplus filesystem type is a hierarchical filesystem designed to replace hfs that allows you to mount Mac OS filesystems. | /etc/modprobe.d/*.conf<br>install hfsplus /bin/false or install hfsplus /bin/true<br>blacklist hfsplus |
| 5 | 1.1.1.5 | Ensure jffs2 kernel module is not available | The jffs2 (journaling flash filesystem 2) filesystem type is a log-structured filesystem used in flash memory devices. | /etc/modprobe.d/*.conf<br>install jffs2 /bin/false or install jffs2 /bin/true<br>blacklist jffs2 |
| 6 | 1.1.1.6 | Ensure squashfs kernel module is not available | The squashfs filesystem type is a compressed read-only Linux filesystem embedded in small footprint systems. A squashfs image can be used without having to first decompress the image. | /etc/modprobe.d/*.conf<br>install squashfs /bin/false or install squashfs /bin/true<br>blacklist squashfs |
| 7 | 1.1.1.7 | Ensure udf kernel module is not available | The udf filesystem type is the universal disk format used to implement ISO/IEC 13346 and ECMA-167 specifications. This is an open vendor filesystem type for data storage on a broad range of media. This filesystem type is necessary to support writing DVDs and newer optical disc formats. | /etc/modprobe.d/*.conf<br>install udf /bin/false or install udf /bin/true<br>blacklist udf |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Expected Value |
|---|---|---|---|---|
| 8 | 1.1.1.8 | Ensure usb-storage kernel module is not available | USB storage provides a means to transfer and store files ensuring persistence and availability of the files independent of network connection status. Its popularity and utility has led to USB-based malware being a simple and common means for network infiltration and a first step to establishing a persistent threat within a networked environment. | /etc/modprobe.d/*.conf<br>install usb-storage /bin/false or install usb-storage /bin/true<br>blacklist usb-storage |
| | **1.1.2** | **Configure Filesystem Partitions** | | |
| 9 | 1.1.2.1.2 | Ensure nodev option set on /tmp partition | The nodev mount option specifies that the filesystem cannot contain special devices. | **If /tmp partition exists:**<br># findmnt -kn /tmp \| grep -v nodev Nothing should be returned<br>**Else, control should not be measured or pass it.** |
| 10 | 1.1.2.1.3 | Ensure nosuid option set on /tmp partition | The nosuid mount option specifies that the filesystem cannot contain setuid files. | **If /tmp partition exists:**<br>Edit the /etc/fstab file and add nosuid to the fourth field (mounting options) for the /tmp partition.<br>**Else, control should not be measured or pass it.** |
| 11 | 1.1.2.2.1 | Ensure /dev/shm is a separate partition | The /dev/shm directory is a world-writable directory that can function as shared memory that facilitates inter process communication (IPC). | **If /dev/shm partition exists:**<br>/dev/shm tmpfs tmpfs rw,nosuid,nodev,noexec,relatime,seclabel<br>**Else, control should not be measured or pass it.** |
| 12 | 1.1.2.2.2 | Ensure nodev option set on /dev/shm partition | The nodev mount option specifies that the filesystem cannot contain special devices. | **If /dev/shm partition exists:**<br># findmnt -kn /dev/shm \| grep -v 'nodev'<br>Nothing should be returned<br>**Else, control should not be measured or pass it.** |
| 13 | 1.1.2.2.3 | Ensure nosuid option set on /dev/shm partition | The nosuid mount option specifies that the filesystem cannot contain setuid files. | **If /dev/shm partition exists:**<br># findmnt -kn /dev/shm \| grep -v 'nosuid'<br>Nothing should be returned<br>**Else, control should not be measured or pass it.** |
| 14 | 1.1.2.2.4 | Ensure noexec option set on /dev/shm partition | The noexec mount option specifies that the filesystem cannot contain executable binaries. | **If /dev/shm partition exists:**<br># findmnt -kn /dev/shm \| grep -v 'noexec'<br>Nothing should be returned<br>**Else, control should not be measured or pass it.** |
| 15 | 1.1.2.3.2 | Ensure nodev option set on /home partition | The nodev mount option specifies that the filesystem cannot contain special devices. | **If /home partition exists:**<br># findmnt -nk /home \| grep -v nodev Nothing should be returned<br>**Else, control should not be measured or pass it.** |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Expected Value |
|---|---|---|---|---|
| 16 | 1.1.2.3.3 | Ensure nosuid option set on /home partition | The nosuid mount option specifies that the filesystem cannot contain setuid files. | **If /home partition exists:**<br># findmnt -nk /home \| grep -v nosuid Nothing should be returned<br>**Else, control should not be measured or pass it.** |
| 17 | 1.1.2.4.2 | Ensure nodev option set on /var partition | The nodev mount option specifies that the filesystem cannot contain special devices. | **If /var partition exists:**<br># findmnt -nk /var \| grep -v nodev Nothing should be returned<br>**Else, control should not be measured or pass it.** |
| 18 | 1.1.2.4.3 | Ensure nosuid option set on /var partition | The nosuid mount option specifies that the filesystem cannot contain setuid files. | **If /var partition exists:**<br># findmnt -nk /var \| grep -v nosuid Nothing should be returned<br>**Else, control should not be measured or pass it.** |
| 19 | 1.1.2.5.2 | Ensure nodev option set on /var/tmp partition | The nodev mount option specifies that the filesystem cannot contain special devices. | **If /var/tmp partition exists:**<br># findmnt -nk /var/tmp \| grep -v nodev Nothing should be returned<br>**Else, control should not be measured or pass it.** |
| 20 | 1.1.2.5.3 | Ensure nosuid option set on /var/tmp partition | The nosuid mount option specifies that the filesystem cannot contain setuid files. | **If /var/tmp partition exists:**<br># findmnt -nk /var/tmp \| grep -v nosuid Nothing should be returned<br>**Else, control should not be measured or pass it.** |
| 21 | 1.1.2.6.2 | Ensure nodev option set on /var/log partition | The nodev mount option specifies that the filesystem cannot contain special devices. | **If /var/log partition exists:**<br># findmnt -nk /var/log \| grep -v nodev Nothing should be returned<br>**Else, control should not be measured or pass it.** |
| 22 | 1.1.2.6.3 | Ensure nosuid option set on /var/log partition | The nosuid mount option specifies that the filesystem cannot contain setuid files. | **If /var/log partition exists:**<br># findmnt -nk /var/log \| grep -v nosuid Nothing should be returned<br>**Else, control should not be measured or pass it.** |
| 23 | 1.1.2.6.4 | Ensure noexec option set on /var/log partition | The noexec mount option specifies that the filesystem cannot contain executable binaries. | **If /var/log partition exists:**<br># findmnt -nk /var/log \| grep -v noexec Nothing should be returned<br>**Else, control should not be measured or pass it.** |
| 24 | 1.1.2.7.2 | Ensure nodev option set on /var/log/audit partition | The nodev mount option specifies that the filesystem cannot contain special devices. | **If /var/log partition exists:**<br># findmnt -nk /var/log/audit \| grep -v nodev Nothing should be returned<br>**Else, control should not be measured or pass it.** |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Expected Value |
|---|---|---|---|---|
| 25 | 1.1.2.7.3 | Ensure nosuid option set on /var/log/audit partition | The nosuid mount option specifies that the filesystem cannot contain setuid files. | **If /var/log/audit partition exists:**<br># findmnt -nk /var/log/audit \| grep -v nosuid<br>Nothing should be returned<br>**Else, control should not be measured or pass it.** |
| 26 | 1.1.2.7.4 | Ensure noexec option set on /var/log/audit partition | The noexec mount option specifies that the filesystem cannot contain executable binaries. | **If /var/log/audit partition exists:**<br># findmnt -nk /var/log/audit \| grep -v noexec<br>Nothing should be returned<br>**Else, control should not be measured or pass it.** |
| | **1.5** | **Mandatory Access Control** | | |
| | **1.5.1** | **Configure SELinux** | | |
| 27 | 1.5.1.1 | Ensure SELinux is installed | SELinux provides Mandatory Access Control. | libselinux-<version> |
| 28 | 1.5.1.2 | Ensure SELinux is not disabled in bootloader configuration | Configure SELINUX to be enabled at boot time and verify that it has not been overwritten by the grub boot parameters. | **permissive or enforcing mode**<br>selinux=0 or enforcing=0 |
| 29 | 1.5.1.3 | Ensure SELinux policy is configured | Configure SELinux to meet or exceed the default targeted policy, which constrains daemons and system software only. | SELINUXTYPE=targeted |
| 30 | 1.5.1.4 | Ensure the SELinux mode is not disabled | SELinux can run in one of three modes: disabled, permissive, or enforcing | **permissive or enforcing mode**<br>SELINUX=enforcing or SELINUX=permissive |
| 31 | 1.5.1.5 | Ensure the SELinux mode is enforcing | SELinux can run in one of three modes: disabled, permissive, or enforcing | **permissive or enforcing mode**<br>SELINUX=enforcing or SELINUX=permissive |
| 32 | 1.5.1.7 | Ensure the MCS Translation Service (mcstrans) is not installed | The mcstransd daemon provides category label information to client processes requesting information. The label translations are defined in /etc/selinux/targeted/setrans.conf | # rpm -q mcstrans<br>package mcstrans is not installed |
| 33 | 1.5.1.8 | Ensure SETroubleshoot is not installed | The SETroubleshoot service notifies desktop users of SELinux denials through a user-friendly interface. The service provides important information around configuration errors, unauthorized intrusions, and other potential errors. | # rpm -q setroubleshoot<br>package setroubleshoot is not installed |
| | **1.7** | **Configure Command Line Warning Banners** | | |
| 34 | 1.7.1 | Ensure message of the day is configured properly | The contents of the /etc/motd file are displayed to users after login and function as a message of the day for authenticated users. | Run the following command and verify no results are returned: # grep -E -i "(\\v\|\\r\|\\m\|\\s\|$(grep '^ID=' /etc/os-release \| cut -d= -f2 \| sed -e 's/"//g'))" /etc/motd |
| 35 | 1.7.2 | Ensure local login warning banner is configured properly | The contents of the /etc/issue file are displayed to users prior to login for local terminals. | Run the following command and verify no results are returned: # grep -E -i "(\\v\|\\r\|\\m\|\\s\|$(grep '^ID=' /etc/os-release \| cut -d= -f2 \| sed -e 's/"//g'))" /etc/issue |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Expected Value |
|---|---|---|---|---|
| 36 | 1.7.3 | Ensure remote login warning banner is configured properly | The contents of the /etc/issue.net file are displayed to users prior to login for remote connections from configured services. | Run the following command and verify no results are returned: # grep -E -i "(\\\v\|\\\r\|\\\m\|\\\s\|$(grep '^ID=' /etc/os-release \| cut -d= -f2 \| sed -e 's/"//g'))" /etc/issue.net |
| 37 | 1.7.4 | Ensure access to /etc/motd is configured | The contents of the /etc/motd file are displayed to users after login and function as a message of the day for authenticated users. | Access: (0644/-rw-r--r--) Uid: ( 0/ root) Gid: ( 0/ root) |
| 38 | 1.7.5 | Ensure access to /etc/issue is configured | The contents of the /etc/issue file are displayed to users prior to login for local terminals. | Access: (0644/-rw-r--r--) Uid: ( 0/ root) Gid: { 0/ root) |
| 39 | 1.7.6 | Ensure access to /etc/issue.net is configured | The contents of the /etc/issue.net file are displayed to users prior to login for remote connections from configured services. | Access: (0644/-rw-r--r--) Uid: ( 0/ root) Gid: ( 0/ root) |
| | **2** | **Services** | | |
| | **2.1** | **Configure Time Synchronization** | | |
| 40 | 2.1.1 | Ensure time synchronization is in use | System time should be synchronized between all systems in an environment. This is typically done by establishing an authoritative time server or set of servers and having all systems synchronize their clocks to them. | # rpm -q chrony<br>chrony-<version> |
| 41 | 2.1.2 | Ensure chrony is configured | chrony is a daemon which implements the Network Time Protocol (NTP) and is designed to synchronize system clocks across a variety of systems and use a source that is highly accurate. More information on chrony can be found at http://chrony.tuxfamily.org/. chrony can be configured to be a client and/or a server. | server <remote-server><br>Example:<br>server ntp1.us.pre.corp iburst<br>server 0.rhel.pool.ntp.org iburst<br>server 1.rhel.pool.ntp.org iburst<br>server 2.rhel.pool.ntp.org iburst<br>server 3.rhel.pool.ntp.org iburst |
| 42 | 2.1.3 | Ensure chrony is not run as the root user | The file /etc/sysconfig/chronyd allows configuration of options for chrony to include the user chrony is run as. By default this is set to the user chrony | OPTIONS="-u chrony" |
| | **2.2** | **Configure Special Purpose Services** | | |
| 43 | 2.2.1 | Ensure autofs services are not in use | autofs allows automatic mounting of devices, typically including CD/DVDs and USB drives. | # systemctl is-enabled autofs.service 2>/dev/null \| grep 'enabled'<br>Nothing should be returned<br><br># systemctl is-active autofs.service 2>/dev/null \| grep '^active'<br>Nothing should be returned<br><br>Note: If the package is required for a dependency<br>• Ensure the dependent package is approved by local site policy<br>• Ensure stopping and masking the service and/or socket meets local site policy |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Expected Value |
|---|---|---|---|---|
| 44 | 2.2.2 | Ensure avahi daemon services are not in use | Avahi is a free zeroconf implementation, including a system for multicast DNS/DNS-SD service discovery. Avahi allows programs to publish and discover services and hosts running on a local network with no specific configuration. For example, a user can plug a computer into a network and Avahi automatically finds printers to print to, files to look at and people to talk to, as well as network services running on the machine. | package avahi is not installed |
| 45 | 2.2.3 | Ensure dhcp server services are not in use | The Dynamic Host Configuration Protocol (DHCP) is a service that allows machines to be dynamically assigned IP addresses. There are two versions of the DHCP protocol DHCPv4 and DHCPv6. At startup the server may be started for one or the other via the -4 or -6 arguments. | package dhcp-server is not installed |
| 46 | 2.2.4 | Ensure dns server services are not in use | The Domain Name System (DNS) is a hierarchical naming system that maps names to IP addresses for computers, services and other resources connected to a network. | package bind is not installed |
| 47 | 2.2.5 | Ensure dnsmasq services are not in use | dnsmasq is a lightweight tool that provides DNS caching, DNS forwarding and DHCP (Dynamic Host Configuration Protocol) services. | package dnsmasq is not installed |
| 48 | 2.2.6 | Ensure samba file server services are not in use | The Samba daemon allows system administrators to configure their Linux systems to share file systems and directories with Windows desktops. Samba will advertise the file systems and directories via the Server Message Block (SMB) protocol. Windows desktop users will be able to mount these directories and file systems as letter drives on their systems. | package samba is not installed |
| 49 | 2.2.7 | Ensure ftp server services are not in use | FTP (File Transfer Protocol) is a traditional and widely used standard tool for transferring files between a server and clients over a network, especially where no authentication is necessary (permits anonymous users to connect to a server). | package vsftpd is not installed |
| 50 | 2.2.8 | Ensure message access server services are not in use | dovecot and cyrus-imapd are open source IMAP and POP3 server packages for Linux based systems. | package dovecot is not installed<br>package cyrus-imapd is not installed |
| 51 | 2.2.10 | Ensure nis server services are not in use | The Network Information Service (NIS), formerly known as Yellow Pages, is a client-server directory service protocol used to distribute system configuration files. The NIS client ( ypbind ) was used to bind a machine to an NIS server and receive the distributed configuration files. | package ypserv is not installed |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Expected Value |
|---|---|---|---|---|
| 52 | 2.2.11 | Ensure print server services are not in use | The Common Unix Print System (CUPS) provides the ability to print to both local and network printers. A system running CUPS can also accept print jobs from remote systems and print them to local printers. It also provides a web based remote administration capability. | package cups is not installed |
| 53 | 2.2.14 | Ensure snmp services are not in use | Simple Network Management Protocol (SNMP) is a widely used protocol for monitoring the health and welfare of network equipment, computer equipment and devices like UPSs. | package net-snmp is not installed |
| 54 | 2.2.15 | Ensure telnet server services are not in use | The telnet-server package contains the telnet daemon, which accepts connections from users from other systems via the telnet protocol. | package telnet-server is not installed |
| 55 | 2.2.16 | Ensure tftp server services are not in use | Trivial File Transfer Protocol (TFTP) is a simple protocol for exchanging files between two TCP/IP machines. TFTP servers allow connections from a TFTP Client for sending and receiving files. | package tftp-server is not installed |
| 56 | 2.2.19 | Ensure xinetd services are not in use | The X Window System provides a Graphical User Interface (GUI) where users can have multiple windows in which to run programs and various add on. The X Windows system is typically used on workstations where users login, but not on servers where users typically do not login. | package xinetd is not installed |
| 57 | 2.2.20 | Ensure X window server services are not in use | The X Window System provides a Graphical User Interface (GUI) where users can have multiple windows in which to run programs and various add on. The X Windows system is typically used on workstations where users login, but not on servers where users typically do not login. | package xorg-x11-server-common is not installed |
| 58 | 2.2.21 | Ensure mail transfer agents are configured for local-only mode | Mail Transfer Agents (MTA), such as sendmail and Postfix, are used to listen for incoming mail and transfer the messages to the appropriate user or mail server. If the system is not intended to be a mail serve | Run the following commands to verify that the MTA is not listening on any non-loopback address ( 127.0.0.1 or ::1 )<br># ss -plntu \| grep -P -- ':25\b' \| grep -Pv -- '\h+(127\.0\.0\.1\|\[?::1\]?):25\b'<br># ss -plntu \| grep -P -- ':465\b' \| grep -Pv -- '\h+(127\.0\.0\.1\|\[?::1\]?):465\b'<br># ss -plntu \| grep -P -- ':587\b' \| grep -Pv -- '\h+(127\.0\.0\.1\|\[?::1\]?):587\b'<br><br>Nothing should be returned |

| | 2.3 | Configure Service Clients | | |
|---|---|---|---|---|
| **Local Ref #** | **CIS RHEL8 #** | **Rule/Control** | **Description** | **Expected Value** |
| 59 | 2.3.1 | Ensure ftp client is not installed | FTP (File Transfer Protocol) is a traditional and widely used standard tool for transferring files between a server and clients over a network, especially where no authentication is necessary (permits anonymous users to connect to a server). | package ftp is not installed |
| 60 | 2.3.2 | Ensure ldap client is not installed | The Lightweight Directory Access Protocol (LDAP) was introduced as a replacement for NIS/YP. It is a service that provides a method for looking up information from a central database. | package openldap-clients is not installed |
| 61 | 2.3.3 | Ensure nis client is not installed | The Network Information Service (NIS), formerly known as Yellow Pages, is a client-server directory service protocol used to distribute system configuration files. The NIS client ( ypbind ) was used to bind a machine to an NIS server and receive the distributed configuration files. | package ypbind is not installe |
| 62 | 2.3.4 | Ensure telnet client is not installed | The telnet package contains the telnet client, which allows users to start connections to other systems via the telnet protocol. | package telnet is not installed |
| 63 | 2.3.5 | Ensure tftp client is not installed | Trivial File Transfer Protocol (TFTP) is a simple protocol for exchanging files between two TCP/IP machines. TFTP servers allow connections from a TFTP Client for sending and receiving files. | package tftp is not installed |
| | **4** | **Access, Authentication and Authorization** | | |
| | **4.1** | **Configure job schedulers** | | |
| | **4.1.1** | **Configure cron** | | |
| 64 | 4.1.1.1 | Ensure cron daemon is enabled and active | The cron daemon is used to execute batch jobs on the system. | enabled or active |
| 65 | 4.1.1.2 | Ensure permissions on /etc/crontab are configured | The /etc/crontab file is used by cron to control its own jobs. The commands in this item make sure that root is the user and group owner of the file and that only the owner can access the file. | Access: (600/-rw-------) Uid: ( 0/ root) Gid: ( 0/ root) |
| 66 | 4.1.1.3 | Ensure permissions on /etc/cron.hourly are configured | This directory contains system cron jobs that need to run on an hourly basis. The files in this directory cannot be manipulated by the crontab command, but are instead edited by system administrators using a text editor. The commands below restrict read/write and search access to user and group root, preventing regular users from accessing this directory. | Access: (700/drwx------) Uid: ( 0/ root) Gid: ( 0/ root) |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Expected Value |
|---|---|---|---|---|
| 67 | 4.1.1.4 | Ensure permissions on /etc/cron.daily are configured | The /etc/cron.daily directory contains system cron jobs that need to run on a daily basis. The files in this directory cannot be manipulated by the crontab command, but are instead edited by system administrators using a text editor. The commands below restrict read/write and search access to user and group root, preventing regular users from accessing this directory. | Access: (700/drwx------) Uid: ( 0/ root) Gid: ( 0/ root) |
| 68 | 4.1.1.5 | Ensure permissions on /etc/cron.weekly are configured | The /etc/cron.weekly directory contains system cron jobs that need to run on a weekly basis. The files in this directory cannot be manipulated by the crontab command, but are instead edited by system administrators using a text editor. The commands below restrict read/write and search access to user and group root, preventing regular users from accessing this directory. | Access: (700/drwx------) Uid: ( 0/ root) Gid: ( 0/ root) |
| 69 | 4.1.1.6 | Ensure permissions on /etc/cron.monthly are configured | The /etc/cron.monthly directory contains system cron jobs that need to run on a monthly basis. The files in this directory cannot be manipulated by the crontab command, but are instead edited by system administrators using a text editor. The commands below restrict read/write and search access to user and group root, preventing regular users from accessing this directory. | Access: (700/drwx------) Uid: ( 0/ root) Gid: ( 0/ root) |
| 70 | 4.1.1.7 | Ensure permissions on /etc/cron.d are configured | The /etc/cron.d directory contains system cron jobs that need to run in a similar manner to the hourly, daily weekly and monthly jobs from /etc/crontab, but require more granular control as to when they run. The files in this directory cannot be manipulated by the crontab command, but are instead edited by system administrators using a text editor. The commands below restrict read/write and search access to user and group root, preventing regular users from accessing this directory. | Access: (700/drwx------) Uid: ( 0/ root) Gid: ( 0/ root) |
| 71 | 4.1.1.8 | Ensure crontab is restricted to authorized users | crontab is the program used to install, deinstall, or list the tables used to drive the cron daemon. Each user can have their own crontab, and though these are files in /var/spool/cron/crontabs, they are not intended to be edited directly. | **if they exist (/etc/cron.allow and /etc/cron.deny):**<br>Access: (640/-rw-r-----) Owner: (root) Group: (root)<br>**-OR- Nothing is returned** |
| | **4.1.2** | **Configure at** | | |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Expected Value |
|---|---|---|---|---|
| 72 | 4.1.2.1 | Ensure at is restricted to authorized users | at allows fairly complex time specifications, extending the POSIX.2 standard. It accepts times of the form HH:MM to run a job at a specific time of day. | Access: (640/-rw-r-----) Owner: (root) Group: (daemon) -OR- Access: (640/-rw-r-----) Owner: (root) Group: (root) **-OR- Nothing is returned** |
| | **4.2** | **Configure SSH Server** | | |
| 73 | 4.2.5 | Ensure sshd Banner is configured | The Banner parameter specifies a file whose contents must be sent to the remote user before authentication is permitted. By default, no banner is displayed. | banner /etc/issue.net |
| 74 | 4.2.7 | Ensure sshd ClientAliveInterval and ClientAliveCountMax are configured | The two options ClientAliveInterval and ClientAliveCountMax control the timeout of SSH sessions. | ClientAliveInterval 15<br>ClientAliveCountMax 3 |
| | **4.4** | **Configure Pluggable Authentication Modules** | | |
| | **4.4.1** | **Configure PAM software packages** | | |
| 75 | 4.4.1.1 | Ensure latest version of pam is installed | Updated versions of PAM include additional functionality | pam-1.3.1-25.el8.x86_64 |
| 76 | 4.4.1.2 | Ensure latest version of authselect is installed | Authselect is a utility that simplifies the configuration of user authentication. Authselect offers ready-made profiles that can be universally used with all modern identity management systems | authselect-1.2.6-1.el8.x86_64 |
| | **4.4.2** | **Configure authselect** | | |
| 77 | 4.4.2.1 | Ensure active authselect profile includes pam modules | A custom profile can be created by copying and customizing one of the default profiles. The default profiles include: sssd, winbind, or the nis. This profile can then be customized to follow site specific requirements. | active authselect profile includes lines for the pwquality, pwhistory, faillock, and unix modules |
| 78 | 4.4.2.2 | Ensure pam_faillock module is enabled | The pam_faillock.so module maintains a list of failed authentication attempts per user during a specified interval and locks the account in case there were more than the configured number of consecutive failed authentications (this is defined by the deny parameter in the faillock configuration). It stores the failure records into per-user files in the tally directory. | pam_faillock is enabled |
| 79 | 4.4.2.3 | Ensure pam_pwquality module is enabled | The pam_pwquality.so module performs password quality checking. This module can be plugged into the password stack of a given service to provide strength-checking for passwords. The code was originally based on pam_cracklib module and the module is backwards compatible with its options. | pam_pwquality is enabled |
| 80 | 4.4.2.4 | Ensure pam_pwhistory module is enabled | The pam_history.so module saves the last passwords for each user in order to force password change history and keep the user from alternating between the same password too frequently. | pam_pwhistory is enabled |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Expected Value |
|---|---|---|---|---|
| 81 | 4.4.2.5 | Ensure pam_unix module is enabled | The pam_unix.so module is the standard Unix authentication module. It uses standard calls from the system's libraries to retrieve and set account information as well as authentication. Usually this is obtained from the /etc/passwd and the /etc/shadow file as well if shadow is enabled. | pam_unix is enabled |
| | **4.4.3** | **Configure pluggable module arguments** | | |
| 82 | 4.4.3.1.1 | Ensure password failed attempts lockout is configured | The deny=5 option will deny access if the number of consecutive authentication failures for this user during the recent interval exceeds . | deny = 5 |
| 83 | 4.4.3.1.2 | Ensure password unlock time is configured | unlock_time=900 - The access will be re-enabled after seconds after the lock out. The value 0 has the same meaning as value never - the access will not be re-enabled without resetting the faillock entries by the faillock(8) command. | unlock_time = 900 |
| 84 | 4.4.3.2.1 | Ensure password number of changed characters is configured | The pwquality difok option sets the number of characters in a password that must not be present in the old password. | /etc/security/pwquality.conf.d/*.conf<br>difok = 2 |
| 85 | 4.4.3.2.2 | Ensure password length is configured | minlen - Minimum acceptable size for the new password (plus one if credits are not disabled which is the default). Cannot be set to lower value than 6. | /etc/security/pwquality.conf.d/*.conf<br>minlen = 14 |
| 86 | 4.4.3.2.3 | Ensure password complexity is configured | Password complexity can be set through: minclass. Dcredit, ucredit, ocredit, lcredit | /etc/security/pwquality.conf.d/*.conf<br>minclass = 4 or "dcredit = -1" "ucredit = -1" "ocredit = -1" "lcredit = -1" |
| 87 | 4.4.3.2.4 | Ensure password same consecutive characters is configured | The pwquality maxrepeat option sets the maximum number of allowed same consecutive characters in a new password. | /etc/security/pwquality.conf.d/*.conf<br>maxrepeat = 3 |
| 88 | 4.4.3.2.5 | Ensure password maximum sequential characters is configured | The pwquality maxsequence option sets the maximum length of monotonic character sequences in the new password. Examples of such sequence are 12345 or fedcb. The check is disabled if the value is 0. | /etc/security/pwquality.conf.d/*.conf<br>maxsequence = 3 |
| 89 | 4.4.3.2.6 | Ensure password dictionary check is enabled | The pwquality dictcheck option sets whether to check for the words from the cracklib dictionary. | /etc/security/pwquality.conf.d/*.conf<br>dictcheck = 0 |
| 90 | 4.4.3.3.1 | Ensure password history remember is configured | The /etc/security/opasswd file stores the users' old passwords and can be checked to ensure that users are not recycling recent passwords. remember = 24 | remember = 24 |
| 91 | 4.4.3.3.3 | Ensure pam_pwhistory includes use_authtok | use_authtok - When password changing enforce the module to set the new password to the one provided by a previously stacked password module | use_authtok is set on the pam_pwhistory.so module lines in the password stack |
| 92 | 4.4.3.4.1 | Ensure pam_unix does not include nullok | The nullok argument overrides the default action of pam_unix.so to not permit the user access to a service if their official password is blank. | nullok argument is not set on the pam_unix.so module |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Expected Value |
|---|---|---|---|---|
| 93 | 4.4.3.4.2 | Ensure pam_unix does not include remember | The remember=n argument saves the last n passwords for each user in /etc/security/opasswd in order to force password change history and keep the user from alternating between the same password too frequently. The MD5 password hash algorithm is used for storing the old passwords. Instead of this option the pam_pwhistory module should be used. The pam_pwhistory module saves the last n passwords for each user in /etc/security/opasswd using the password hash algorithm set on the pam_unix module. This allows for the sha512 hash algorithm to be used. | remember argument is not set on the pam_unix.so module |
| 94 | 4.4.3.4.3 | Ensure pam_unix includes a strong password hashing algorithm | A cryptographic hash function converts an arbitrary-length input into a fixed length output. Password hashing performs a one-way transformation of a password, turning the password into another string, called the hashed password. | sha512 - OR - yescrypt |
| 95 | 4.4.3.4.4 | Ensure pam_unix includes use_authtok | use_authtok - When password changing enforce the module to set the new password to the one provided by a previously stacked password module | use_authtok is set on the pam_unix.so module lines in the password stack |
| | **4.5** | **User Accounts and Environment** | | |
| | **4.5.1** | **Configure shadow password suite parameters** | | |
| 96 | 4.5.1.1 | Ensure strong password hashing algorithm is configured | A cryptographic hash function converts an arbitrary-length input into a fixed length output. Password hashing performs a one-way transformation of a password, turning the password into another string, called the hashed password. | crypt_style = sha512<br>ENCRYPT_METHOD SHA512 |
| 97 | 4.5.1.2 | Ensure password expiration is 365 days or less | The PASS_MAX_DAYS parameter in /etc/login.defs allows an administrator to force passwords to expire once they reach a defined age. It is recommended that the PASS_MAX_DAYS parameter be set to less than or equal to 365 days. | PASS_MAX_DAYS 365 |
| 98 | 4.5.1.3 | Ensure password expiration warning days is 7 or more | The PASS_WARN_AGE parameter in /etc/login.defs allows an administrator to notify users that their password will expire in a defined number of days. It is recommended that the PASS_WARN_AGE parameter be set to 7 or more days. | PASS_WARN_AGE 7 |
| | **4.5.2** | **Configure root and system accounts and environment** | | |
| 99 | 4.5.2.2 | Ensure root user umask is configured | The user file-creation mode mask (umask) is used to determine the file permission for newly created directories and files. In Linux, the default permissions for any newly created directory is 0777 (rwxrwxrwx), and for any newly created file it is 0666 (rw-rw-rw-). | umask to be 0027 |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Expected Value |
|---|---|---|---|---|
| 100 | 4.5.2.4 | Ensure root password is set | Access to root should be secured at all times. | Password set, SHA512 crypt |
| | **4.5.3** | **Configure user default environment** | | |
| 101 | 4.5.3.2 | Ensure default user shell timeout is configured | TMOUT is an environmental setting that determines the timeout of a shell in seconds. | • As multiple lines:<br>TMOUT=900<br>readonly TMOUT<br>export TMOUT<br>• As a single line:<br>readonly TMOUT=900 ; export TMOUT |
| | **5** | **Logging and Auditing** | | |
| | **5.1** | **Configure Logging** | | |
| | **5.1.1** | **Configure rsyslog** | | |
| 102 | 5.1.1.1 | Ensure rsyslog is installed | The rsyslog software is recommended in environments where journald does not meet operation requirements. | rsyslog-<version> |
| 103 | 5.1.1.2 | Ensure rsyslog service is enabled | Once the rsyslog package is installed, ensure that the service is enabled. | enabled |
| 104 | 5.1.1.3 | Ensure journald is configured to send logs to rsyslog | Data from systemd-journald may be stored in volatile memory or persisted locally on the server. Utilities exist to accept remote export of systemd-journald logs, however, use of the rsyslog service provides a consistent means of log collection and export. | /etc/systemd/journald.conf.d/*.conf<br>ForwardToSyslog=yes |
| 105 | 5.1.1.4 | Ensure rsyslog default file permissions are configured | RSyslog will create logfiles that do not already exist on the system. This setting controls what permissions will be applied to these newly created files. | $FileCreateMode 0640 |
| 106 | 5.1.1.5 | Ensure logging is configured | The /etc/rsyslog.conf and /etc/rsyslog.d/*.conf files specifies rules for logging and which files are to be used to log certain classes of messages. | /etc/rsyslog.conf and /etc/rsyslog.d/*.conf files to ensure appropriate logging is set |
| 107 | 5.1.1.6 | Ensure rsyslog is configured to send logs to a remote log host | RSyslog supports the ability to send log events it gathers to a remote log host or to receive messages from remote hosts, thus enabling centralized log management. | @@syslog.wt.mx.us.corp:6514;RSYSLOG_SyslogProtocol23Format |
| 108 | 5.1.1.7 | Ensure rsyslog is not configured to receive logs from a remote client | RSyslog supports the ability to receive messages from remote hosts, thus acting as a log server. Clients should not receive data from other hosts. | # grep -Ps -- '^\h*module\(load="imtcp"\)' /etc/rsyslog.conf /etc/rsyslog.d/*.conf<br># grep -Ps -- '^\h*input\(type="imtcp" port="514"\)' /etc/rsyslog.conf /etc/rsyslog.d/*.conf<br><br>No output expected. |
| | **5.1.2** | **Configure journald** | | |
| 109 | 5.1.2.1.4 | Ensure journald is not configured to receive logs from a remote client | Journald supports the ability to receive messages from remote hosts, thus acting as a log server. Clients should not receive data from other hosts. | masked |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Expected Value |
|---|---|---|---|---|
| 110 | 5.1.2.2 | Ensure journald service is enabled | Ensure that the systemd-journald service is enabled to allow capturing of logging events. | static |
| 111 | 5.1.2.3 | Ensure journald is configured to compress large log files | The journald system includes the capability of compressing overly large files to avoid filling up the system with logs or making the logs unmanageably large. | Compress=yes |
| 112 | 5.1.2.4 | Ensure journald is configured to write logfiles to persistent disk | Data from journald may be stored in volatile memory or persisted locally on the server. Logs in memory will be lost upon a system reboot. By persisting logs to local disk on the server they are protected from loss due to a reboot. | Storage=persistent |
| 113 | 5.1.3 | Ensure logrotate is configured | The system includes the capability of rotating log files regularly to avoid filling up the system with logs or making the logs unmanageably large. The file /etc/logrotate.d/syslog is the configuration file used to rotate log files created by syslog or rsyslog. | /etc/logrotate.conf and /etc/logrotate.d/* to ensure logs are rotated according to site policy |
| 114 | 5.1.4 | Ensure all logfiles have appropriate access configured | Log files stored in /var/log/ contain logged information from many services on the system and potentially from other logged hosts as well. | /var/log/ have appropriate permissions and ownership<br>**l_auser="root"**<br>**l_agroup="(root\|utmp)"** |
| | **5.2** | **Configure System Accounting (auditd)** | | |
| | **5.2.1** | **Ensure auditing is enabled** | | |
| 115 | 5.2.1.1 | Ensure audit is installed | auditd is the userspace component to the Linux Auditing System. It's responsible for writing audit records to the disk. | audit-<version> |
| | **5.3** | **Configure Integrity Checking** | | |
| 116 | 5.3.1 | Ensure AIDE is installed | Advanced Intrusion Detection Environment (AIDE) is an intrusion detection tool that uses predefined rules to check the integrity of files and directories in the Linux operating system. AIDE has its own database to check the integrity of files and directories. aide takes a snapshot of files and directories including modification times, permissions, and file hashes which can then be used to compare against the current state of the filesystem to detect modifications to the system. | aide-<version> |
| 117 | 5.3.2 | Ensure filesystem integrity is regularly checked | Periodic checking of the filesystem integrity is needed to detect changes to the filesystem. | enabled |
| | **6** | **System Maintenance** | | |
| | **6.1** | **System File Permissions** | | |
| 118 | 6.1.1 | Ensure permissions on /etc/passwd are configured | The /etc/passwd file contains user account information that is used by many system utilities and therefore must be readable for these utilities to operate. | Access: (0644/-rw-r--r--) Uid: ( 0/ root) Gid: ( 0/ root) |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Expected Value |
|---|---|---|---|---|
| 119 | 6.1.2 | Ensure permissions on /etc/passwd- are configured | The /etc/passwd- file contains backup user account information. | Access: (0644/-rw-r--r--) Uid: ( 0/ root) Gid: ( 0/ root) |
| 120 | 6.1.3 | Ensure permissions on /etc/opasswd are configured | /etc/security/opasswd and it's backup /etc/security/opasswd.old hold user's previous passwords if pam_unix or pam_pwhistory is in use on the system | **if they exist -** Access: (0600/-rw-------) Uid: ( 0/ root) Gid: ( 0/ root) -OR- Nothing is returned |
| 121 | 6.1.4 | Ensure permissions on /etc/group are configured | The /etc/group file contains a list of all the valid groups defined in the system. The command below allows read/write access for root and read access for everyone else. | Access: (0644/-rw-r--r--) Uid: ( 0/ root) Gid: ( 0/ root) |
| 122 | 6.1.5 | Ensure permissions on /etc/group- are configured | The /etc/group- file contains a backup list of all the valid groups defined in the system. | Access: (0644/-rw-r--r--) Uid: ( 0/ root) Gid: ( 0/ root) |
| 123 | 6.1.6 | Ensure permissions on /etc/shadow are configured | The /etc/shadow file is used to store the information about user accounts that is critical to the security of those accounts, such as the hashed password and other security information. | Access: (0/----------) Uid: ( 0/ root) Gid: ( 0/ root) |
| 124 | 6.1.7 | Ensure permissions on /etc/shadow- are configured | The /etc/shadow- file is used to store backup information about user accounts that is critical to the security of those accounts, such as the hashed password and other security information. | Access: (0/----------) Uid: ( 0/ root) Gid: ( 0/ root) |
| 125 | 6.1.8 | Ensure permissions on /etc/gshadow are configured | The /etc/gshadow file is used to store the information about groups that is critical to the security of those accounts, such as the hashed password and other security information. | Access: (0/----------) Uid: ( 0/ root) Gid: ( 0/ root) |
| 126 | 6.1.9 | Ensure permissions on /etc/gshadow- are configured | The /etc/gshadow- file is used to store backup information about groups that is critical to the security of those accounts, such as the hashed password and other security information. | Access: (0/----------) Uid: ( 0/ root) Gid: ( 0/ root) |
| | **6.2** | **Local User and Group Settings** | | |
| 127 | 6.2.1 | Ensure accounts in /etc/passwd use shadowed passwords | Local accounts can use shadowed passwords. With shadowed passwords, the passwords are saved in shadow password file, /etc/shadow, encrypted by a salted one-way hash. Accounts with a shadowed password have an x in the second field in /etc/passwd. | No output is returned |
| 128 | 6.2.2 | Ensure /etc/shadow password fields are not empty | An account with an empty password field means that anybody may log in as that user without providing a password. | No output is returned |
| 129 | 6.2.3 | Ensure all groups in /etc/passwd exist in /etc/group | Over time, system administration errors and changes can lead to groups being defined in /etc/passwd but not in /etc/group . | No output is returned |

## 4.3 Out of Scope

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| | **1.1.2** | **Configure Filesystem Partitions** | | |
| 1 | 1.1.2.1.1 | Ensure /tmp is a separate partition | The /tmp directory is a world-writable directory used for temporary storage by all users and some applications. | This has to be configured from Machine Factory Team. |
| 2 | 1.1.2.1.4 | Ensure noexec option set on /tmp partition | The noexec mount option specifies that the filesystem cannot contain executable binaries. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Application will fail to execute from tmp. |
| 3 | 1.1.2.3.1 | Ensure separate partition exists for /home | The /home directory is used to support disk storage needs of local users. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>This has to be configured from Machine Factory Team. |
| 4 | 1.1.2.4.1 | Ensure separate partition exists for /var | The /var directory is used by daemons and other system services to temporarily store dynamic data. Some directories created by these processes may be world-writable. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>This has to be configured from Machine Factory Team. |
| 5 | 1.1.2.5.1 | Ensure separate partition exists for /var/tmp | The /var/tmp directory is a world-writable directory used for temporary storage by all users and some applications. Temporary files residing in /var/tmp are to be preserved between reboots. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>This has to be configured from Machine Factory Team. |
| 6 | 1.1.2.5.4 | Ensure noexec option set on /var/tmp partition | The noexec mount option specifies that the filesystem cannot contain executable binaries. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Application will fail to execute from tmp. |
| 7 | 1.1.2.6.1 | Ensure separate partition exists for /var/log | The /var/log directory is used by system services to store log data. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>This has to be configured from Machine Factory Team. |
| 8 | 1.1.2.7.1 | Ensure separate partition exists for /var/log/audit | The auditing daemon, auditd, stores log data in the /var/log/audit directory. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>This has to be configured from Machine Factory Team. |
| | **1.2** | **Configure Software and Patch Management** | | |
| 9 | 1.2.1 | Ensure GPG keys are configured | The RPM Package Manager implements GPG key signing to verify package integrity during and after installation. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Patching was halt due to touching the gpgcheck configurations |
| 10 | 1.2.2 | Ensure gpgcheck is globally activated | The gpgcheck option, found in the main section of the /etc/dnf/dnf.conf and individual /etc/yum.repos.d/* files, determines if an RPM package's signature is checked prior to its installation. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Patching was halt due to touching the gpgcheck configurations |
| 11 | 1.2.3 | Ensure repo_gpgcheck is globally activated | The repo_gpgcheck option, found in the main section of the /etc/dnf/dnf.conf and individual /etc/yum.repos.d/* files, will perform a GPG signature check on the repodata. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Patching was halt due to touching the gpgcheck configurations |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 12 | 1.2.4 | Ensure package manager repositories are configured | Systems need to have the respective package manager repositories configured to ensure that the system is able to receive the latest patches and updates. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Patching was halt due to touching the gpgcheck configurations |
| 13 | 1.2.5 | Ensure updates, patches, and additional security software are installed | Periodically patches are released for included software either due to security flaws or to include additional functionality. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Patching was halt due to touching the gpgcheck configurations |
| | **1.3** | **Configure Secure Boot Settings** | | |
| 14 | 1.3.1 | Ensure bootloader password is set | Setting the boot loader password will require that anyone rebooting the sys | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Jail break will fail to reset the password. |
| 15 | 1.3.2 | Ensure permissions on bootloader config are configured | The grub files contain information on boot settings and passwords for unlocking boot options. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Jail break will fail to reset the password. |
| | **1.4** | **Configure Additional Process Hardening** | | |
| 16 | 1.4.1 | Ensure address space layout randomization (ASLR) is enabled | Address space layout randomization (ASLR) is an exploit mitigation technique which randomly arranges the address space of key data areas of a process. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Legacy proprietary apps crash after hardening. Debugging becomes confusing. Performance testing reproducibility. |
| 17 | 1.4.2 | Ensure ptrace_scope is restricted | The ptrace() system call provides a means by which one process (the "tracer") may observe and control the execution of another p | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Legacy proprietary apps crash after hardening. Debugging becomes confusing. Performance testing reproducibility. |
| 18 | 1.4.3 | Ensure core dump backtraces are disabled | A core dump is the memory of an executable program. It is generally used to determine why a program aborted. It can also be used to glean confidential information from a core file. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Legacy proprietary apps crash after hardening. Debugging becomes confusing. Performance testing reproducibility. |
| 19 | 1.4.4 | Ensure core dump storage is disabled | A core dump is the memory of an executable program. It is generally used to determine why a program aborted. It can also be used to glean confidential information from a core file. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Legacy proprietary apps crash after hardening. Debugging becomes confusing. Performance testing reproducibility. |
| | **1.5** | **Mandatory Access Control** | | |
| | **1.5.1** | **Configure SELinux** | | |
| 20 | 1.5.1.6 | Ensure no unconfined services exist | Unconfined processes run in unconfined domains | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Legacy proprietary apps crash after hardening. Debugging becomes confusing. Performance testing reproducibility. |
| | **1.6** | **Configure system wide crypto policy** | | |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 21 | 1.6.1 | Ensure system wide crypto policy is not set to legacy | When a system-wide policy is set up, the default behavior of applications will be to follow the policy. Applications will be unable to use algorithms and protocols that do not meet the policy, unless you explicitly request the application to do so. The system-wide crypto-policies followed by the crypto core components allow consistently deprecating and disabling algorithms system-wide. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Application still using old encryption and keys are configured in the moveit application. Applying the hardening, all FTP jobs failed. |
| 22 | 1.6.2 | Ensure system wide crypto policy disables sha1 hash and signature support | SHA-1 (Secure Hash Algorithm) is a cryptographic hash function that produces a 160 bit hash value. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Application still using old encryption and keys are configured in the moveit application. Applying the hardening, all FTP jobs failed. |
| 23 | 1.6.3 | Ensure system wide crypto policy disables cbc for ssh | Cypher Block Chaining (CBC) is an algorithm that uses a block cipher. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Application still using old encryption and keys are configured in the moveit application. Applying the hardening, all FTP jobs failed. |
| 24 | 1.6.4 | Ensure system wide crypto policy disables macs less than 128 bits | Message Authentication Code (MAC) algorithm is a family of cryptographic functions that is parameterized by a symmetric key. Each of the functions can act on input data (called a “message”) of variable length to produce an output value of a specified length. The output value is called the MAC of the input message. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Application still using old encryption and keys are configured in the moveit application. Applying the hardening, all FTP jobs failed. |
| | **1.8** | **Configure GNOME Display Manager** | | |
| 25 | 1.8.1 | Ensure GNOME Display Manager is removed | The GNOME Display Manager (GDM) is a program that manages graphical display servers and handles graphical user logins. | We do not use GNOME |
| 26 | 1.8.2 | Ensure GDM login banner is configured | GDM is the GNOME Display Manager which handles graphical login for GNOME based systems. | We do not use GNOME |
| 27 | 1.8.3 | Ensure GDM disable-user-list option is enabled | GDM is the GNOME Display Manager which handles graphical login for GNOME based systems. The disable-user-list option controls if a list of users is displayed on the login screen | We do not use GNOME |
| 28 | 1.8.4 | Ensure GDM screen locks when the user is idle | GNOME Desktop Manager can make the screen lock automatically whenever the user is idle for some amount of time. | We do not use GNOME |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 29 | 1.8.5 | Ensure GDM screen locks cannot be overridden | GNOME Desktop Manager can make the screen lock automatically whenever the user is idle for some amount of time. | We do not use GNOME |
| 30 | 1.8.6 | Ensure GDM automatic mounting of removable media is disabled | By default GNOME automatically mounts removable media when inserted as a convenience to the user. | We do not use GNOME |
| 31 | 1.8.7 | Ensure GDM disabling automatic mounting of removable media is not overridden | By default GNOME automatically mounts removable media when inserted as a convenience to the user. By using the lockdown mode in dconf, you can prevent users from changing specific settings. To lock down a dconf key or subpath, create a locks subdirectory in the keyfile directory. The files inside this directory contain a list of keys or subpaths to lock. Just as with the keyfiles, you may add any number of files to this directory. | We do not use GNOME |
| 32 | 1.8.8 | Ensure GDM autorun-never is enabled | The autorun-never setting allows the GNOME Desktop Display Manager to disable autorun through GDM. | We do not use GNOME |
| 33 | 1.8.9 | Ensure GDM autorun-never is not overridden | The autorun-never setting allows the GNOME Desktop Display Manager to disable autorun through GDM. By using the lockdown mode in dconf, you can prevent users from changing specific settings. To lock down a dconf key or subpath, create a locks subdirectory in the keyfile directory. The files inside this directory contain a list of keys or subpaths to lock. Just as with the keyfiles, you may add any number of files to this directory. | We do not use GNOME |
| 34 | 1.8.10 | Ensure XDMCP is not enabled | X Display Manager Control Protocol (XDMCP) is designed to provide authenticated access to display management services for remote displays | We do not use GNOME |
| | **2.2** | **Configure Special Purpose Services** | | |
| 35 | 2.2.9 | Ensure network file system services are not in use | The Network File System (NFS) is one of the first and most widely distributed file systems in the UNIX environment. It provides the ability for systems to mount file systems of other servers through the network. | Managed via Firewall over network |
| 36 | 2.2.12 | Ensure rpcbind services are not in use | The rpcbind utility maps RPC services to the ports on which they listen. RPC processes notify rpcbind when they start, registering the ports they are listening on and the RPC program numbers they expect to serve. The client system then contacts rpcbind on the server with a particular RPC program number. The rpcbind.service redirects the client to the proper port number so it can communicate with the requested service. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Mount.nfs rpcbinf failures, connection refused. Legacy versions of Oracle RAC, Storage agents still uses rpcbind. |
| 37 | 2.2.13 | Ensure rsync services are not in use | The rsyncd.service can be used to synchronize files between systems over network links. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Application uses rsync to transfer files, which will break. |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 38 | 2.2.17 | Ensure web proxy server services are not in use | Squid is a standard proxy server used in many distributions and environments. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Application uses squid as proxy. So it will break. |
| 39 | 2.2.18 | Ensure web server services are not in use | Web servers provide the ability to host web site content. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Rolledback due to last recent incident of hardening. |
| 40 | 2.2.22 | Ensure only approved services are listening on a network interface | A network port is identified by its number, the associated IP address, and the type of the communication protocol such as TCP or UDP. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Rolledback due to last recent incident of hardening. |
| | **3** | **Network** | | |
| | **3.1** | **Configure Network Devices** | | |
| 41 | 3.1.1 | Ensure IPv6 status is identified | Internet Protocol Version 6 (IPv6) is the most recent version of Internet Protocol (IP). It's designed to supply IP addressing and additional security to support the predicted growth of connected devices. IPv6 is based on 128-bit addressing and can support 340 undecillion, which is 340 trillion3 addresses. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Rolledback due to last recent incident of hardening. |
| 42 | 3.1.2 | Ensure wireless interfaces are disabled | Wireless networking is used when wired networks are unavailable. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Rolledback due to last recent incident of hardening. |
| 43 | 3.1.3 | Ensure bluetooth services are not in use | Bluetooth is a short-range wireless technology standard that is used for exchanging data between devices over short distances. It employs UHF radio waves in the ISM bands, from 2.402 GHz to 2.48 GHz. It is mainly used as an alternative to wire connections. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Rolledback due to last recent incident of hardening. |
| | **3.2** | **Configure Network Kernel Modules** | | |
| 44 | 3.2.1 | Ensure dccp kernel module is not available | The Datagram Congestion Control Protocol (DCCP) is a transport layer protocol that supports streaming media and telephony. DCCP provides a way to gain access to congestion control, without having to do it at the application layer, but does not provide in-sequence delivery. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Rolledback due to last recent incident of hardening. |
| 45 | 3.2.2 | Ensure tipc kernel module is not available | The Transparent Inter-Process Communication (TIPC) protocol is designed to provide communication between cluster nodes. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Rolledback due to last recent incident of hardening. |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 46 | 3.2.3 | Ensure rds kernel module is not available | The Reliable Datagram Sockets (RDS) protocol is a transport layer protocol designed to provide low-latency, high-bandwidth communications between cluster nodes. It was developed by the Oracle Corporation. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Rolledback due to last recent incident of hardening. |
| 47 | 3.2.4 | Ensure sctp kernel module is not available | The Stream Control Transmission Protocol (SCTP) is a transport layer protocol used to support message oriented communication, with several streams of messages in one connection. It serves a similar function as TCP and UDP, incorporating features of both. It is message-oriented like UDP, and ensures reliable in-sequence transport of messages with congestion control like TCP. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Rolledback due to last recent incident of hardening. |
| | **3.3** | **Configure Network Kernel Parameters** | | |
| 48 | 3.3.1 | Ensure ip forwarding is disabled | The net.ipv4.ip_forward and net.ipv6.conf.all.forwarding flags are used to tell the system whether it can forward packets or not. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Rolledback due to last recent incident of hardening. |
| 49 | 3.3.2 | Ensure packet redirect sending is disabled | ICMP Redirects are used to send routing information to other hosts. As a host itself does not act as a router (in a host only configuration), there is no need to send redirects. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Rolledback due to last recent incident of hardening. |
| 50 | 3.3.3 | Ensure bogus icmp responses are ignored | Setting net.ipv4.icmp_ignore_bogus_error_responses to 1 prevents the kernel from logging bogus responses (RFC-1122 non-compliant) from broadcast reframes, keeping file systems from filling up with useless log messages. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Rolledback due to last recent incident of hardening. |
| 51 | 3.3.4 | Ensure broadcast icmp requests are ignored | Setting net.ipv4.icmp_echo_ignore_broadcasts to 1 will cause the system to ignore all ICMP echo and timestamp requests to broadcast and multicast addresses. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Rolledback due to last recent incident of hardening. |
| 52 | 3.3.5 | Ensure icmp redirects are not accepted | ICMP redirect messages are packets that convey routing information and tell your host (acting as a router) to send packets via an alternate path. It is a way of allowing an outside routing device to update your system routing tables. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Rolledback due to last recent incident of hardening. |
| 53 | 3.3.6 | Ensure secure icmp redirects are not accepted | Secure ICMP redirects are the same as ICMP redirects, except they come from gateways listed on the default gateway list. It is assumed that these gateways are known to your system, and that they are likely to be secure. | Moved to Out-of-Scope as part of operational risk and application dependencies<br>Issue: Rolledback due to last recent incident of hardening. |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 54 | 3.3.7 | Ensure reverse path filtering is enabled | Setting net.ipv4.conf.all.rp_filter and net.ipv4.conf.default.rp_filter to 1 forces the Linux kernel to utilize reverse path filtering on a received packet to determine if the packet was valid. Essentially, with reverse path filtering, if the return packet does not go out the same interface that the corresponding source packet came from, the packet is dropped (and logged if log_martians is set). | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 55 | 3.3.8 | Ensure source routed packets are not accepted | In networking, source routing allows a sender to partially or fully specify the route packets take through a network. In contrast, non-source routed packets travel a path determined by routers in the network. In some cases, systems may not be routable or reachable from some locations (e.g. private addresses vs. Internet routable), and so source routed packets would need to be used. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 56 | 3.3.9 | Ensure suspicious packets are logged | When enabled, this feature logs packets with un-routable source addresses to the kernel log. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 57 | 3.3.10 | Ensure tcp syn cookies is enabled | When tcp_syncookies is set, the kernel will handle TCP SYN packets normally until the half-open connection queue is full, at which time, the SYN cookie functionality kicks in. SYN cookies work by not using the SYN queue at all. Instead, the kernel simply replies to the SYN with a SYN\|ACK, but will include a specially crafted TCP sequence number that encodes the source and destination IP address and port number and the time the packet was sent. A legitimate connection would send the ACK packet of the three way handshake with the specially crafted sequence number. This allows the system to verify that it has received a valid response to a SYN cookie and allow the connection, even though there is no corresponding SYN in the queue. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 58 | 3.3.11 | Ensure ipv6 router advertisements are not accepted | This setting disables the system's ability to accept IPv6 router advertisements. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| | **3.4** | **Configure Host Based Firewall** | | |
| | **3.4.1** | **Configure a firewall utility** | | |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 59 | 3.4.1.1 | Ensure nftables is installed | nftables provides a new in-kernel packet classification framework that is based on a network-specific Virtual Machine (VM) and a new nft userspace command line tool. nftables reuses the existing Netfilter subsystems such as the existing hook infrastructure, the connection tracking system, NAT, userspace queuing and logging subsystem. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 60 | 3.4.1.2 | Ensure a single firewall configuration utility is in use | FirewallD - Is a firewall service daemon that provides a dynamic customizable host-based firewall with a D-Bus interface. Being dynamic, it enables creating, changing, and deleting the rules without the necessity to restart the firewall daemon each time the rules are changed | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| | **3.4.2** | **Configure firewall rules** | | |
| | **3.4.2.1** | **Ensure nftables base chains exist** | | |
| 61 | 3.4.2.2 | Ensure host based firewall loopback traffic is configured | Configure the loopback interface to accept traffic. Configure all other interfaces to deny traffic to the loopback network | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 62 | 3.4.2.3 | Ensure firewalld drops unnecessary services and ports | Services and ports can be accepted or explicitly rejected or dropped by a zone. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 63 | 3.4.2.4 | Ensure nftables established connections are configured | Configure the firewall rules for new outbound and established connections | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 64 | 3.4.2.5 | Ensure nftables default deny firewall policy | Base chain policy is the default verdict that will be applied to packets reaching the end of the chain. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| | **4.2** | **Configure SSH Server** | | |
| 65 | 4.2.1 | Ensure permissions on /etc/ssh/sshd_config are configured | The file /etc/ssh/sshd_config, and files ending in .conf in the /etc/ssh/sshd_config.d directory, contain configuration specifications for sshd. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 66 | 4.2.2 | Ensure permissions on SSH private host key files are configured | An SSH private key is one of two files used in SSH public key authentication. In this authentication method, the possession of the private key is proof of identity. Only a private key that corresponds to a public key will be able to authenticate successfully. The private keys need to be stored and handled carefully, and no copies of the private key should be distributed. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |
| 67 | 4.2.3 | Ensure permissions on SSH public host key files are configured | An SSH public key is one of two files used in SSH public key authentication. In this authentication method, a public key is a key that can be used for verifying digital signatures generated using a corresponding private key. Only a public key that corresponds to a private key will be able to authenticate successfully. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |
| 68 | 4.2.4 | Ensure sshd access is configured | There are several options available to limit which users and group can access the system via SSH. It is recommended that at least one of the following options be leveraged: AllowUsers, AllowGroups, DenyUsers, DenyGroups | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |
| 69 | 4.2.6 | Ensure sshd Ciphers are configured | This variable limits the ciphers that SSH can use during communication. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |
| 70 | 4.2.8 | Ensure sshd DisableForwarding is enabled | The DisableForwarding parameter disables all forwarding features, including X11, ssh-agent(1), TCP and StreamLocal. This option overrides all other forwarding-related options and may simplify restricted configurations. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |
| 71 | 4.2.9 | Ensure sshd HostbasedAuthentication is disabled | The HostbasedAuthentication parameter specifies if authentication is allowed through trusted hosts via the user of .rhosts, or /etc/hosts.equiv, along with successful public key client host authentication. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 72 | 4.2.10 | Ensure sshd IgnoreRhosts is enabled | The IgnoreRhosts parameter specifies that .rhosts and .shosts files will not be used in RhostsRSAAuthentication or HostbasedAuthentication. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |
| 73 | 4.2.11 | Ensure sshd KexAlgorithms is configured | Key exchange is any method in cryptography by which cryptographic keys are exchanged between two parties, allowing use of a cryptographic algorithm. If the sender and receiver wish to exchange encrypted messages, each must be equipped to encrypt messages to be sent and decrypt messages received | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |
| 74 | 4.2.12 | Ensure sshd LoginGraceTime is configured | The LoginGraceTime parameter specifies the time allowed for successful authentication to the SSH server. The longer the Grace period is the more open unauthenticated connections can exist. Like other session controls in this session the Grace Period should be limited to appropriate organizational limits to ensure the service is available for needed access. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |
| 75 | 4.2.13 | Ensure sshd LogLevel is configured | LogLevel gives the verbosity level that is used when logging messages from sshd. The possible values are: QUIET, FATAL, ERROR, INFO, VERBOSE, DEBUG, DEBUG1, DEBUG2, and DEBUG3. The default is INFO. DEBUG and DEBUG1 are equivalent. DEBUG2 and DEBUG3 each specify higher levels of debugging output. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |
| 76 | 4.2.14 | Ensure sshd MACs are configured | This variable limits the types of MAC algorithms that SSH can use during communication. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 77 | 4.2.15 | Ensure sshd MaxAuthTries is configured | The MaxAuthTries parameter specifies the maximum number of authentication attempts permitted per connection. When the login failure count reaches half the number, error messages will be written to the syslog file detailing the login failure. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |
| 78 | 4.2.16 | Ensure sshd MaxSessions is configured | The MaxSessions parameter specifies the maximum number of open sessions permitted from a given connection. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |
| 79 | 4.2.17 | Ensure sshd MaxStartups is configured | The MaxStartups parameter specifies the maximum number of concurrent unauthenticated connections to the SSH daemon. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |
| 80 | 4.2.18 | Ensure sshd PermitEmptyPasswords is disabled | The PermitEmptyPasswords parameter specifies if the SSH server allows login to accounts with empty password strings. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |
| 81 | 4.2.19 | Ensure sshd PermitRootLogin is disabled | The PermitRootLogin parameter specifies if the root user can log in using SSH. The default is prohibit-password. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |
| 82 | 4.2.20 | Ensure sshd PermitUserEnvironment is disabled | The PermitUserEnvironment option allows users to present environment options to the SSH daemon. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 83 | 4.2.21 | Ensure sshd UsePAM is enabled | The UsePAM directive enables the Pluggable Authentication Module (PAM) interface. If set to yes this will enable PAM authentication using ChallengeResponseAuthentication and PasswordAuthentication directives in addition to PAM account and session module processing for all authentication types. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |
| 84 | 4.2.22 | Ensure sshd crypto_policy is not set | System-wide Crypto policy can be over-ridden or opted out of for openSSH | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Applying hardening on ssh and touching ssd configuration file, moveit FTP jobs failed. |
| | **4.3** | **Configure privilege escalation** | | |
| 85 | 4.3.1 | Ensure sudo is installed | sudo allows a permitted user to execute a command as the superuser or another user, as specified by the security policy. The invoking user's real (not effective) user ID is used to determine the user name with which to query the security policy. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |
| 86 | 4.3.2 | Ensure sudo commands use pty | sudo can be configured to run only from a pseudo terminal (pseudo-pty). | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |
| 87 | 4.3.3 | Ensure sudo log file exists | The Defaults logfile entry sets the path to the sudo log file. Setting a path turns on logging to a file; negating this option turns it off. By default, sudo logs via syslog. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |
| 88 | 4.3.4 | Ensure users must provide password for escalation | The operating system must be configured so that users must provide a password for privilege escalation. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 89 | 4.3.5 | Ensure re-authentication for privilege escalation is not disabled globally | The operating system must be configured so that users must re-authenticate for privilege escalation. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |
| 90 | 4.3.6 | Ensure sudo authentication timeout is configured correctly | sudo caches used credentials for a default of 5 minutes. This is for ease of use when there are multiple administrative tasks to perform. The timeout can be modified to suit local security policies. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |
| 91 | 4.3.7 | Ensure access to the su command is restricted | The su command allows a user to run a command or shell as another user. The program has been superseded by sudo, which allows for more granular control over privileged access. Normally, the su command can be executed by any user. By uncommenting the pam_wheel.so statement in /etc/pam.d/su, the su command will only allow users in a specific groups to execute su. This group should be empty to reinforce the use of sudo for privileged access. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |
| | **4.4.3** | **Configure pluggable module arguments** | | |
| 92 | 4.4.3.1.3 | Ensure password failed attempts lockout includes root account | even_deny_root - Root account can become locked as well as regular accounts. root_unlock_time=n - This option implies even_deny_root option. Allow access after n seconds to root account after the account is locked. In case the option is not specified the value is the same as of the unlock_time option. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: CyberArk will fail. |
| 93 | 4.4.3.2.7 | Ensure password quality is enforced for the root user | If the pwquality enforce_for_root option is enabled, the module will return error on failed check even if the user changing the password is root. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: CyberArk will fail. |
| 94 | 4.4.3.3.2 | Ensure password history is enforced for the root user | If the pwhistory enforce_for_root option is enabled, the module will enforce password history for the root user as well | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: CyberArk will fail. |
| | **4.5** | **User Accounts and Environment** | | |
| | **4.5.1** | **Configure shadow password suite parameters** | | |
| 95 | 4.5.1.4 | Ensure inactive password lock is 30 days or less | User accounts that have been inactive for over a given period of time can be automatically disabled. It is recommended that accounts that are inactive for 30 days after password expiration be disabled. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Service accounts will fail. |
| 96 | 4.5.1.5 | Ensure all users last password change date is in the past | All users should have a password change date in the past. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Service accounts will fail. |

| | 4.5.2 | Configure root and system accounts and environment | | |
|---|---|---|---|---|
| **Local Ref #** | **CIS RHEL8 #** | **Rule/Control** | **Description** | **Rationale** |
| 97 | 4.5.2.1 | Ensure default group for the root account is GID 0 | The usermod command can be used to specify which group the root account belongs to. This affects permissions of files that are created by the root account. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 98 | 4.5.2.3 | Ensure system accounts are secured | There are a number of accounts provided with most distributions that are used to manage applications and are not intended to provide an interactive shell. Furthermore, | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| | **4.5.3** | **Configure user default environment** | | |
| 99 | 4.5.3.1 | Ensure nologin is not listed in /etc/shells | /etc/shells is a text file which contains the full pathnames of valid login shells. This file is consulted by chsh and available to be queried by other programs. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 100 | 4.5.3.3 | Ensure default user umask is configured | The user file-creation mode mask (umask) is used to determine the file permission for newly created directories and files. In Linux, the default permissions for any newly created directory is 0777 (rwxrwxrwx), and for any newly created file it is 0666 (rw-rw-rw-). | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| | **5.1.2** | **Configure journald** | | |
| 101 | 5.1.2.1.1 | Ensure systemd-journal-remote is installed | Journald (via systemd-journal-remote) supports the ability to send log events it gathers to a remote log host or to receive messages from remote hosts, thus enabling centralized log management. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 102 | 5.1.2.1.2 | Ensure systemd-journal-remote is configured | Journald (via systemd-journal-remote) supports the ability to send log events it gathers to a remote log host or to receive messages from remote hosts, thus enabling centralized log management. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 103 | 5.1.2.1.3 | Ensure systemd-journal-remote is enabled | Journald (via systemd-journal-remote) supports the ability to send log events it gathers to a remote log host or to receive messages from remote hosts, thus enabling centralized log management. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 104 | 5.1.2.5 | Ensure journald is not configured to send logs to rsyslog | Data from journald should be kept in the confines of the service and not forwarded on to other services. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 105 | 5.1.2.6 | Ensure journald log rotation is configured per site policy | Journald includes the capability of rotating log files regularly to avoid filling up the system with logs or making the logs unmanageably large. The file /etc/systemd/journald.conf is the configuration file used to specify how logs generated by Journald should be rotated. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| | **5.2** | **Configure System Accounting (auditd)** | | |
| | **5.2.1** | **Ensure auditing is enabled** | | |
| 106 | 5.2.1.2 | Ensure auditing for processes that start prior to auditd is enabled | Configure grub2 so that processes that are capable of being audited can be audited even if they start up prior to auditd startup. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 107 | 5.2.1.3 | Ensure audit_backlog_limit is sufficient | The backlog limit has a default setting of 64 | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 108 | 5.2.1.4 | Ensure auditd service is enabled | Turn on the auditd daemon to record system events. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Servers came down due to audit hardening. So have to rollback all the rules. |
| | **5.2.2** | **Configure Data Retention** | | |
| 109 | 5.2.2.1 | Ensure audit log storage size is configured | Configure the maximum size of the audit log file. Once the log reaches the maximum size, it will be rotated and a new log file will be started. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Servers came down due to audit hardening. So have to rollback all the rules. |
| 110 | 5.2.2.2 | Ensure audit logs are not automatically deleted | The max_log_file_action setting determines how to handle the audit log file reaching the max file size. A value of keep_logs will rotate the logs but never delete old logs. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Servers came down due to audit hardening. So have to rollback all the rules. |
| 111 | 5.2.2.3 | Ensure system is disabled when audit logs are full | The auditd daemon can be configured to halt the system or put the system in single user mode, if no free space is available or an error is detected on the partition that holds the audit log files. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Servers came down due to audit hardening. So have to rollback all the rules. |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 112 | 5.2.2.4 | Ensure system warns when audit logs are low on space | The auditd daemon can be configured to halt the system, put the system in single user mode or send a warning message, if the partition that holds the audit log files is low on space. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Servers came down due to audit hardening. So have to rollback all the rules. |
| | **5.2.3** | **Configure auditd rules** | | |
| 113 | 5.2.3.1 | Ensure changes to system administration scope (sudoers) is collected | Monitor scope changes for system administrators. If the system has been properly configured to force system administrators to log in as themselves first and then use the sudo command to execute privileged commands, it is possible to monitor changes in scope. The file /etc/sudoers, or files in /etc/sudoers.d, will be written to when the file(s) or related attributes have changed. The audit records will be tagged with the identifier "scope". | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 114 | 5.2.3.2 | Ensure actions as another user are always logged | sudo provides users with temporary elevated privileges to perform operations, either as the superuser or another user. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 115 | 5.2.3.3 | Ensure events that modify the sudo log file are collected | Monitor the sudo log file. If the system has been properly configured to disable the use of the su command and force all administrators to have to log in first and then use sudo to execute privileged commands, then all administrator commands will be logged to /var/log/sudo.log . Any time a command is executed, an audit event will be triggered as the /var/log/sudo.log file will be opened for write and the executed administration command will be written to the log. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 116 | 5.2.3.4 | Ensure events that modify date and time information are collected | Capture events where the system date and/or time has been modified. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 117 | 5.2.3.5 | Ensure events that modify the system's network environment are collected | Record changes to network environment files or system calls. The below parameters monitors the following system calls, and write an audit event on system call exit | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 118 | 5.2.3.6 | Ensure use of privileged commands are collected | Monitor privileged programs, those that have the setuid and/or setgid bit set on execution, to determine if unprivileged users are running these commands. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 119 | 5.2.3.7 | Ensure unsuccessful file access attempts are collected | Monitor for unsuccessful attempts to access files. The following parameters are associated with system calls that control files | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 120 | 5.2.3.8 | Ensure events that modify user/group information are collected | Record events affecting the modification of user or group information, including that of passwords and old passwords if in use | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 121 | 5.2.3.9 | Ensure discretionary access control permission modification events are collected | Monitor changes to file permissions, attributes, ownership and group. The parameters in this section track changes for system calls that affect file permissions and attributes. The following commands and system calls effect the permissions, ownership and various attributes of files | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 122 | 5.2.3.10 | Ensure successful file system mounts are collected | Monitor the use of the mount system call. The mount (and umount ) system call controls the mounting and unmounting of file systems. The parameters below configure the system to create an audit record when the mount system call is used by a non-privileged user | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 123 | 5.2.3.11 | Ensure session initiation information is collected | Monitor session initiation events. The parameters in this section track changes to the files associated with session events | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 124 | 5.2.3.12 | Ensure login and logout events are collected | Monitor login and logout events. The parameters below track changes to files associated with login/logout events | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 125 | 5.2.3.13 | Ensure file deletion events by users are collected | Monitor the use of system calls associated with the deletion or renaming of files and file attributes. This configuration statement sets up monitoring for | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 126 | 5.2.3.14 | Ensure events that modify the system's Mandatory Access Controls are collected 774 | Monitor SELinux, an implementation of mandatory access controls. The parameters below monitor any write access (potential additional, deletion or modification of files in the directory) or attribute changes to the /etc/selinux/ and /usr/share/selinux/ directories. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 127 | 5.2.3.15 | Ensure successful and unsuccessful attempts to use the chcon command are recorded | The operating system must generate audit records for successful/unsuccessful uses of the chcon command | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 128 | 5.2.3.16 | Ensure successful and unsuccessful attempts to use the setfacl command are recorded | The operating system must generate audit records for successful/unsuccessful uses of the setfacl command | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 129 | 5.2.3.17 | Ensure successful and unsuccessful attempts to use the chacl command are recorded | The operating system must generate audit records for successful/unsuccessful uses of the chacl command | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 130 | 5.2.3.18 | Ensure successful and unsuccessful attempts to use the usermod command are recorded | The operating system must generate audit records for successful/unsuccessful uses of the usermod command | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 131 | 5.2.3.19 | Ensure kernel module loading unloading and modification is collected | Monitor the loading and unloading of kernel modules. All the loading / listing / dependency checking of modules is done by kmod via symbolic links | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 132 | 5.2.3.20 | Ensure the audit configuration is immutable | Set system audit so that audit rules cannot be modified with auditctl . Setting the flag "-e 2" forces audit to be put in immutable mode. Audit changes can only be made on system reboot. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| 133 | 5.2.3.21 | Ensure the running and on disk configuration is the same | The Audit system have both on disk and running configuration. It is possible for these configuration settings to differ. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Rolledback due to last recent incident of hardening. |
| | **5.2.4** | **Configure auditd file access** | | |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 134 | 5.2.4.1 | Ensure the audit log directory is 0750 or more restrictive | The audit log directory contains audit log files. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Servers came down due to audit hardening. So have to rollback all the rules. |
| 135 | 5.2.4.2 | Ensure audit log files are mode 0640 or less permissive | Audit log files contain information about the system and system activity. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Servers came down due to audit hardening. So have to rollback all the rules. |
| 136 | 5.2.4.3 | Ensure only authorized users own audit log files | Audit log files contain information about the system and system activity. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Servers came down due to audit hardening. So have to rollback all the rules. |
| 137 | 5.2.4.4 | Ensure only authorized groups are assigned ownership of audit log files | Audit log files contain information about the system and system activity. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Servers came down due to audit hardening. So have to rollback all the rules. |
| 138 | 5.2.4.5 | Ensure audit configuration files are 640 or more restrictive | Audit configuration files control auditd and what events are audited. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Servers came down due to audit hardening. So have to rollback all the rules. |
| 139 | 5.2.4.6 | Ensure audit configuration files are owned by root | Audit configuration files control auditd and what events are audited. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Servers came down due to audit hardening. So have to rollback all the rules. |
| 140 | 5.2.4.7 | Ensure audit configuration files belong to group root | Audit configuration files control auditd and what events are audited. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Servers came down due to audit hardening. So have to rollback all the rules. |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 141 | 5.2.4.8 | Ensure audit tools are 755 or more restrictive | Audit tools include, but are not limited to, vendor-provided and open source audit tools needed to successfully view and manipulate audit information system activity and records. Audit tools include custom queries and report generators. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Servers came down due to audit hardening. So have to rollback all the rules. |
| 142 | 5.2.4.9 | Ensure audit tools are owned by root | Audit tools include, but are not limited to, vendor-provided and open source audit tools needed to successfully view and manipulate audit information system activity and records. Audit tools include custom queries and report generators. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Servers came down due to audit hardening. So have to rollback all the rules. |
| 143 | 5.2.4.10 | Ensure audit tools belong to group root | Audit tools include, but are not limited to, vendor-provided and open source audit tools needed to successfully view and manipulate audit information system activity and records. Audit tools include custom queries and report generators. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Servers came down due to audit hardening. So have to rollback all the rules. |
| | **5.3** | **Configure Integrity Checking** | | |
| 144 | 5.3.3 | Ensure cryptographic mechanisms are used to protect the integrity of audit tools | Audit tools include, but are not limited to, vendor-provided and open source audit tools needed to successfully view and manipulate audit information system activity and records. Audit tools include custom queries and report generators. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Servers came down due to audit hardening. So have to rollback all the rules. |
| | **6** | **System Maintenance** | | |
| | **6.1** | **System File Permissions** | | |
| 145 | 6.1.10 | Ensure permissions on /etc/shells are configured | /etc/shells is a text file which contains the full pathnames of valid login shells. This file is consulted by chsh and available to be queried by other programs | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |
| 146 | 6.1.11 | Ensure world writable files and directories are secured | World writable files are the least secure. Data in world-writable files can be modified and compromised by any user on the system. World writable files may also indicate an incorrectly written script or program that could potentially be the cause of a larger compromise to the system's integrity. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |
| 147 | 6.1.12 | Ensure no unowned or ungrouped files or directories exist | Administrators may delete users or groups from the system and neglect to remove all files and/or directories owned by those users or groups. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 148 | 6.1.13 | Ensure SUID and SGID files are reviewed | The owner of a file can set the file's permissions to run with the owner's or group's permissions, even if the user running the program is not the owner or a member of the group. The most common reason for a SUID or SGID program is to enable users to perform functions (such as changing their password) that require root privileges. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |
| 149 | 6.1.14 | Audit system file permissions | The RPM Package Manager has a number of useful options. One of these, the -V for RPM option, can be used to verify that system packages are correctly installed. The -V option can be used to verify a particular package or to verify all system packages. If no output is returned, the package is installed correctly. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |
| | **6.2** | **Local User and Group Settings** | | |
| 150 | 6.2.4 | Ensure no duplicate UIDs exist | Although the useradd program will not let you create a duplicate User ID (UID), it is possible for an administrator to manually edit the /etc/passwd file and change the UID field. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |
| 151 | 6.2.5 | Ensure no duplicate GIDs exist | Although the groupadd program will not let you create a duplicate Group ID (GID), it is possible for an administrator to manually edit the /etc/group file and change the GID field. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |
| 152 | 6.2.6 | Ensure no duplicate user names exist | Although the useradd program will not let you create a duplicate user name, it is possible for an administrator to manually edit the /etc/passwd file and change the username. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |

| Local Ref # | CIS RHEL8 # | Rule/Control | Description | Rationale |
|---|---|---|---|---|
| 153 | 6.2.7 | Ensure no duplicate group names exist | Although the groupadd program will not let you create a duplicate group name, it is possible for an administrator to manually edit the /etc/group file and change the group name. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |
| 154 | 6.2.8 | Ensure root path integrity | The root user can execute any command on the system and could be fooled into executing programs unintentionally if the PATH is not set correctly. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |
| 155 | 6.2.9 | Ensure root is the only UID 0 account | Any account with UID 0 has superuser privileges on the system. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: CyberArk failes |
| 156 | 6.2.10 | Ensure local interactive user home directories are configured | The user home directory is space defined for the particular user to set local environment variables and to store personal files. While the system administrator can establish secure permissions for users' home directories, the users can easily override these. Users can be defined in /etc/passwd without a home directory or with a home directory that does not actually exist. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |
| 157 | 6.2.11 | Ensure local interactive user dot files access is configured | While the system administrator can establish secure permissions for users' "dot" files, the users can easily override these. | Moved to Out-of-Scope as part of operational risk and application dependencies Issue: Application account user authentication failed. |

## 5 RELATED DOCUMENTS

| Document Type | Department | Owner | Document Title |
|---|---|---|---|
| Policy | Technology | Santander US Chief Data Officer | Data Management Operating Policy |
| Standard | Technology | Santander US Head of Infrastructure Operations | Security Architecture Standard |
| Standard | Technology | Santander US Head of Infrastructure Operations | Secure Build & Configuration Management Standard |
| Standard | Technology | Santander US Head of Infrastructure Operations | Software Distribution Standard |
| Standard | Technology | Santander US Head of Infrastructure Operations | Asset Management Standard |
| Standard | Technology | Santander US Head of Infrastructure Operations | Change and Release Management Standard |

## 6 SOURCE DOCUMENTS

| Source | Version |
|---|---|
| CIS Red Hat Enterprise Linux | 7 v3.1.1 |
| CIS Red Hat Enterprise Linux | 7 v3.0.1 |
| Santander Group Linux Servers Hardening Guide | V2 - 29/07/2022 |
| CIS Red Hat Enterprise Linux 8 | v3.0.0 - 10-30-2023 |
| CIS Red Hat Enterprise Linux 9 | v2.0.0 - 06-24-2024 |

# 7 SUBSIDIARY ENDORSEMENT

| Approving Body | Governance Committee Approval or Endorsement | Final Approval Date |
|---|---|---|
| Santander Bank CISO | Endorsement | 1/5/2026 |
| Santander Bank Head of Infrastructure Operations | Endorsement | 1/5/2026 |
| Santander Consumer CISO | Endorsement | 12/10/2025 |
| Santander Consumer Sr. Director, Infrastructure Operations | Endorsement | 12/9/2025 |
| BSNY CISO | Endorsement | 12/22/2025 |
| BSNY Head of Infrastructure Operations | Endorsement | 12/22/2025 |
| SanCap CISO | Endorsement | 12/22/2025 |
| SanCap Head of Infrastructure Operations | Endorsement | 12/22/2025 |
| BSI CISO | Endorsement | 12/10/2025 |
| BSI Head of Infrastructure Operations | Endorsement | 12/10/2025 |